

Incident Analysis Report: Business Email Compromise (BEC)

Project Information

Organization: SwiftCart Logistics Ltd.

Assessment Type: Security Hardening Assessment using the NIST Cybersecurity Framework (CSF)

Incident Category: Business Email Compromise (BEC)

Security Level: High

Prepared By: Odhiambo Justin Gabriel

Date: June 2026

Executive Summary

During the security assessment of SwiftCart Logistics Ltd, a simulated Business Email Compromise (BEC) scenario was analysed to evaluate the organization's ability to prevent, detect, respond to, and recover from email-based attacks.

The assessment revealed several weaknesses in identity protection, email security, and user awareness that could allow attackers to gain unauthorized access to corporate email accounts. Although no actual financial losses occurred in this hypothetical scenario, the attack demonstrated how a single compromised account could expose sensitive information, facilitate internal phishing campaigns, and potentially lead to fraudulent financial transactions.

The purpose of this report is to document the incident, analyse its root causes, assess the business impact, and provide recommendations aligned with the NIST Cybersecurity Framework.

Organizational Background

SwiftCart Logistics Ltd is a regional logistics and transportation company operating across East Africa. The company manages transportation services, warehousing operations, inventory tracking, and last-mile delivery solutions for commercial clients.

The organization employs approximately 250 staff members and relies heavily on Microsoft 365 services for communication and collaboration. Employees frequently exchange financial information, shipment schedules, invoices, customer details, and operational reports through email.

Because email is one of the primary communication channels within the organization, it represents a high-value target for cybercriminals.

Incident Overview

Incident Description

A finance department employee received an email appearing to originate from Microsoft Support.

The email claimed that unusual activity had been detected on the employee's account and immediate verification was required to prevent account suspension.

The message included:

- Microsoft branding
- Corporate formatting
- Professional language
- A hyperlink directing the user to a counterfeit login portal

Believing the message was legitimate, the employee entered corporate credentials into the fraudulent website.

The attacker immediately obtained access to the employee's Microsoft 365 account and established persistence through mailbox rule manipulation.

Attack Timeline

Phase 1: Phishing Email Delivery

The attacker distributed a phishing email targeting finance department personnel.

The finance department was selected because employees within this group frequently handle invoices, payment approvals, and financial transactions, making them attractive targets for financially motivated attackers.

Phase 2: Credential Harvesting

The employee clicked the embedded link and was redirected to a fake Microsoft login page.

The website closely resembled the legitimate Microsoft authentication portal.

After entering credentials, the username and password were transmitted directly to the attacker.

Phase 3: Unauthorized Account Access

Using the stolen credentials, the attacker successfully authenticated to Microsoft 365.

Because multi-factor authentication was not enforced for all employees, the attacker was able to gain access using only the stolen password.

This significantly lowered the difficulty of account compromise.

Phase 4: Persistence Establishment

Once inside the mailbox, the attacker created email forwarding rules.

The objective was to:

- Monitor communications
- Collect sensitive information
- Maintain visibility even if the password changed
- Hide evidence of malicious activity

The attacker also configured rules that automatically moved specific messages into archive folders to reduce the likelihood of detection.

Phase 5: Internal Reconnaissance

The attacker began reviewing emails, contacts, and organizational communications.

The purpose of this activity was to identify:

- Executive personnel
- Financial approval processes
- Vendor relationships
- Potential targets for further compromise

At this stage, the attacker was preparing for possible financial fraud or additional phishing attacks.

Indicators of Compromise

The following indicators suggested unauthorized access:

1. Suspicious Authentication Activity

Authentication logs revealed successful sign-in attempts from an IP address located outside the organization's operational regions.

The company maintains offices only within East Africa, making foreign login attempts inherently suspicious.

2. Unusual Login Timing

The account was accessed outside the employee's normal working hours.

Behavioural deviations are important because attackers frequently operate from different time zones than their victims.

3. Mailbox Rule Creation

New inbox rules were created shortly after account compromise.

Attackers commonly use mailbox rules to:

- Hide communications
- Forward sensitive information
- Maintain access to future correspondence

Mailbox rule creation is therefore considered a high-confidence indicator of account compromise.

4. Multiple Failed Authentication Attempts

Several unsuccessful login attempts preceded the successful login.

This pattern often indicates attackers testing stolen credentials before gaining access.

Investigation Process

1. Initial Triage

The investigation began after Microsoft Defender and Microsoft 365 generated alerts relating to suspicious sign-in activity.

The primary objective during triage was determining whether the login represented legitimate employee behaviour or malicious activity.

Analysts reviewed:

- Sign-in logs
- Audit logs
- User activity records
- Authentication history

The analysis confirmed that the login originated from an unfamiliar geographic location and device.

2. User Verification

The affected employee was contacted directly.

The employee confirmed:

- They had received an account verification email
- They clicked the provided link
- They entered their credentials

This confirmation significantly increased confidence that a phishing attack had occurred.

Scope Assessment

Investigators needed to determine how much access the attacker obtained.

The following questions guided the investigation:

1. Was sensitive data accessed?

Email records were reviewed to identify whether confidential documents had been opened or downloaded.

2. Were additional accounts targeted?

Security analysts examined outbound email activity to determine whether the compromised account had been used to distribute phishing messages internally.

3. Were financial systems affected?

Since the compromised account belonged to a finance employee, analysts investigated whether invoice approvals or payment requests had been altered.

4. Did the attacker establish persistence?

Mailbox rules and account configurations were reviewed to identify mechanisms that could allow continued access.

Impact Assessment

1. Confidentiality Impact

High

The attacker gained access to business communications and potentially sensitive financial information.

Exposure of this information could facilitate future attacks against the organization.

2. Integrity Impact

Medium

No evidence suggested modification of business records.

However, the attacker possessed sufficient access to alter communications and potentially influence financial decisions.

3. Availability Impact

Low

The attack did not disrupt business operations.

Employees retained access to email services throughout the incident.

Overall Risk Rating

High

Although operational disruption was limited, the combination of credential theft, unauthorized mailbox access, and exposure of sensitive information resulted in a high-risk event.

Root Cause Analysis

Several factors contributed to the success of the attack.

1. Lack of Mandatory Multi-Factor Authentication

The most significant contributing factor was the absence of mandatory MFA enforcement.

Passwords alone are vulnerable to phishing attacks.

Even strong passwords become ineffective once disclosed to attackers.

MFA introduces an additional verification step that significantly increases the difficulty of unauthorized access.

2. Insufficient User Awareness

The employee failed to recognize common phishing indicators.

This suggests security awareness training was either absent or ineffective.

Employees represent an important security control because they are often the final barrier between attackers and organizational assets.

3. Weak Email Security Controls

The phishing email successfully reached the user's inbox.

This indicates opportunities to strengthen email filtering and anti-phishing controls.

Improved filtering could have prevented user interaction entirely.

4. Limited Monitoring of Mailbox Rules

The organization lacked monitoring mechanisms capable of generating alerts when forwarding rules were created.

Mailbox rule creation is a common attacker technique and should be treated as a security-relevant event.

Containment Actions

Following confirmation of compromise, several immediate actions were performed.

1. Account Suspension

The affected account was temporarily disabled.

This action prevented further unauthorized access while preserving evidence.

2. Password Reset

Credentials were reset and new password requirements were enforced.

This ensured previously stolen credentials could no longer be used.

3. Session Revocation

All active authentication sessions were terminated.

This prevented the attacker from maintaining access through existing tokens.

4. Mailbox Rule Removal

Unauthorized forwarding and hiding rules were removed.

Failure to remove these rules could allow continued information leakage.

Recovery Actions

1. MFA Enrollment

The affected user was enrolled in multi-factor authentication.

This significantly reduced the likelihood of future account compromise.

2. Security Validation

Administrators verified:

- No additional persistence mechanisms existed
- No malicious forwarding rules remained
- No unauthorized applications were connected

3. User Education

The employee received targeted phishing awareness guidance.

The objective was not punishment but risk reduction.

Employees who experience phishing attacks often become stronger defenders when provided with appropriate training.

Lessons Learned

1. Several key lessons emerged from this incident.

Email remains a primary attack vector.

Attackers continue to exploit trust rather than technical vulnerabilities.

2. Credentials alone are insufficient protection.

Modern organizations should assume passwords will eventually be exposed.

Security architecture should therefore rely on layered controls rather than password security alone.

3. Monitoring must extend beyond authentication.

Successful attackers often create persistence mechanisms after obtaining access.

Mailbox rule monitoring provides valuable visibility into these activities.

4. User training remains critical.

Technology alone cannot eliminate phishing risk.

Well-trained employees significantly improve organizational resilience.

Security Hardening Recommendations

Priority 1 Recommendations

1. Enforce Multi-Factor Authentication

All employee accounts should require MFA.

This recommendation addresses the primary weakness identified during the assessment.

2. Disable Legacy Authentication

Legacy protocols often bypass modern authentication protections.

Removing them reduces the organization's attack surface.

3. Implement Conditional Access Policies

Conditional access can restrict authentication attempts from risky locations, devices, and behaviours.

This reduces the likelihood of unauthorized access even when credentials are compromised.

Priority 2 Recommendations

1. Conduct Quarterly Phishing Simulations

Simulations provide measurable insights into employee awareness levels and training effectiveness.

2. Improve Email Filtering

Advanced anti-phishing controls should be implemented to identify and block malicious emails before delivery.

3. Monitor Mailbox Rule Creation

Automatic alerting should be configured whenever forwarding rules are created or modified.

Priority 3 Recommendations

1. Establish Security Metrics

Metrics should include:

- Phishing click rate
- MFA adoption rate
- Time to detect incidents
- Time to contain incidents

Tracking these measurements enables management to evaluate security improvements over time.

NIST Cybersecurity Framework Mapping

1. IDENTIFY

The organization must identify:

- Critical business processes
- Financial systems
- High-value user accounts
- Sensitive business information

Failure to identify critical assets makes effective protection impossible.

2. PROTECT

The following controls should be implemented:

- Multi-factor authentication
- Security awareness training
- Conditional access policies
- Email security controls
- Strong password policies

These controls reduce the likelihood of successful compromise.

3. DETECT

Detection capabilities should include:

- Suspicious login monitoring
- Impossible travel detection
- Mailbox rule monitoring
- Authentication anomaly alerts
- Security event logging

These capabilities improve visibility and reduce attacker dwell time.

4. RESPOND

The organization should maintain documented procedures for:

- Incident validation
- User communication
- Credential revocation
- Session termination
- Escalation procedures

Effective response reduces incident impact.

5. RECOVER

Recovery activities should include:

- Secure account restoration
- Validation of security controls
- User re-enablement
- Post-incident review
- Lessons learned implementation

Recovery is not complete until identified weaknesses have been addressed and future risk has been reduced.